Sécurité des systèmes informatiques

Objectifs et domaines d'application de la sécurité informatique

Abdeltouab Belbekkouche

a.belbekkouche@umontreal.ca

Université de Montréal

Contenu

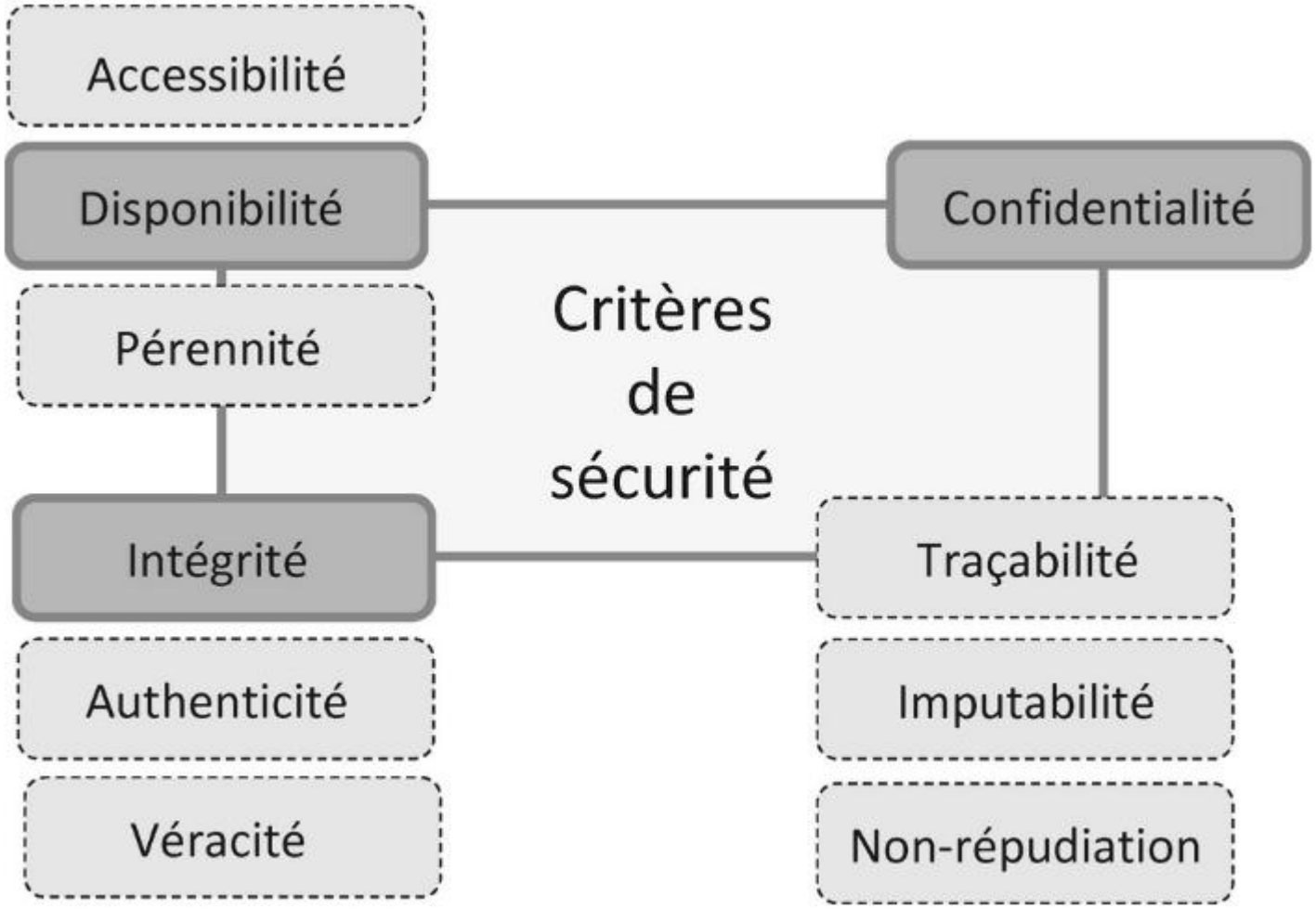
- Objectifs de sécurité
- Domaines d'application de la sécurité informatique
- Diriger la sécurité
- Architecture de sécurité

Objectifs de sécurité

- La notion de sécurité fait référence à la propriété d'un système, d'un service ou d'une entité
- Elle s'exprime le plus souvent par les **objectifs** suivants
  - La disponibilité (D)
  - L'intégrité (I)
  - La confidentialité (C)

  } Critères **DIC** (ou **CIA** en anglais)
- Plus des **fonctions** de sécurité
  - Authentification
  - Non-répudiation
  - Imputabilité

Objectifs de sécurité (suite)



Disponibilité

- Des services, systèmes, données, etc.
- La période de temps pendant laquelle le service offert par une ressource est opérationnel
- **Capacité**
  - Le volume de travail susceptible d'être pris en charge durant la période de disponibilité d'un service (serveur ou réseau par exemple)
- **Accessibilité** (pour l'ensemble des ayants droit)
  - Avec des temps de réponse acceptables
- Dimensionnement approprié, redondance des infrastructures, gestion opérationnelle, maintenance efficace

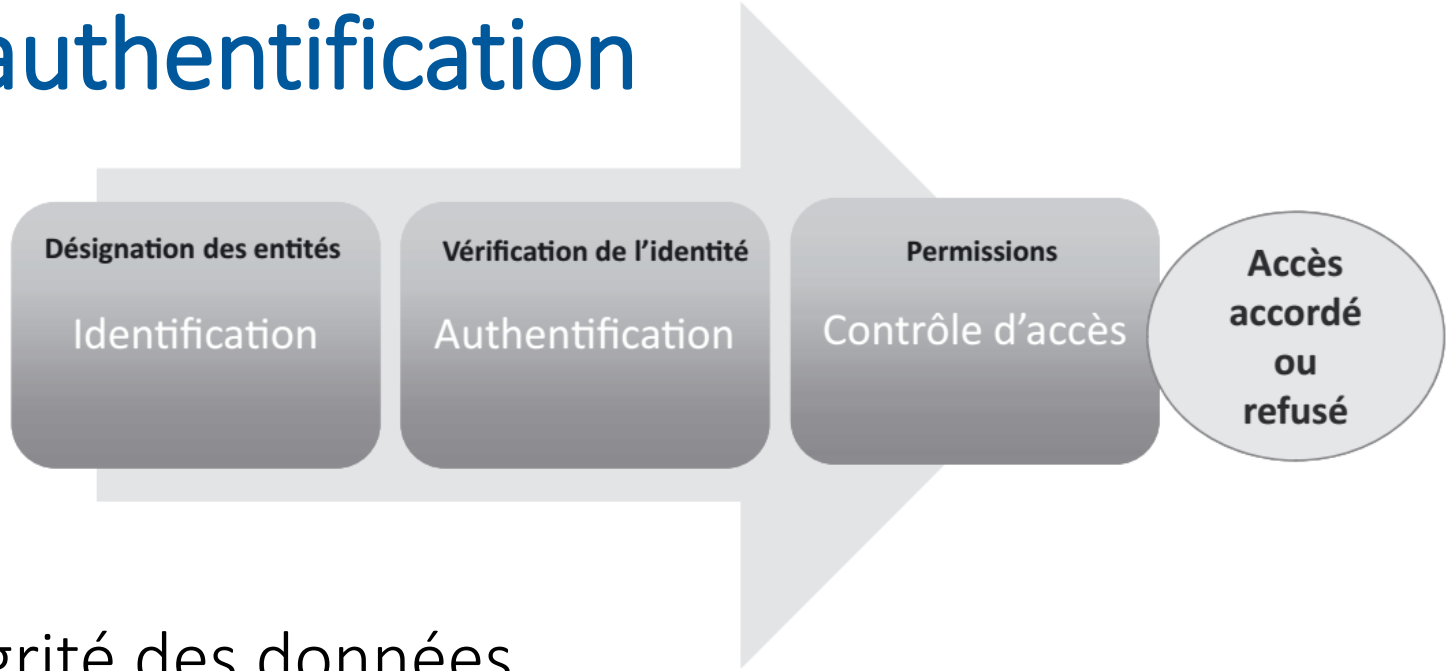
Intégrité

- Des ressources physiques et logiques (équipements, données, traitements, transactions, services)
- Non détruites (altération totale) ou modifiées (altération partielle) à l'insu de leurs propriétaires de manière intentionnelle ou accidentelle
- À satisfaire par des mesures appropriées (chiffrement par exemple) afin de pouvoir atteindre un certain niveau de confiance dans les contenus et le fonctionnement des infrastructures informatiques et télécoms
- Télécommunications: transfert de données (écoutes actives)
- Traitement de l'information: logiciels d'application, systèmes d'exploitation, procédures de sauvegarde, etc.

Confidentialité

- « *La confidentialité est le maintien du secret des informations …* » - Le Petit Robert
- Dans le contexte de l'informatique et des réseaux de communication
  - *« La protection des données contre une divulgation non autorisée »*
- Contrôle d'accès
- Chiffrement

Identification et authentification

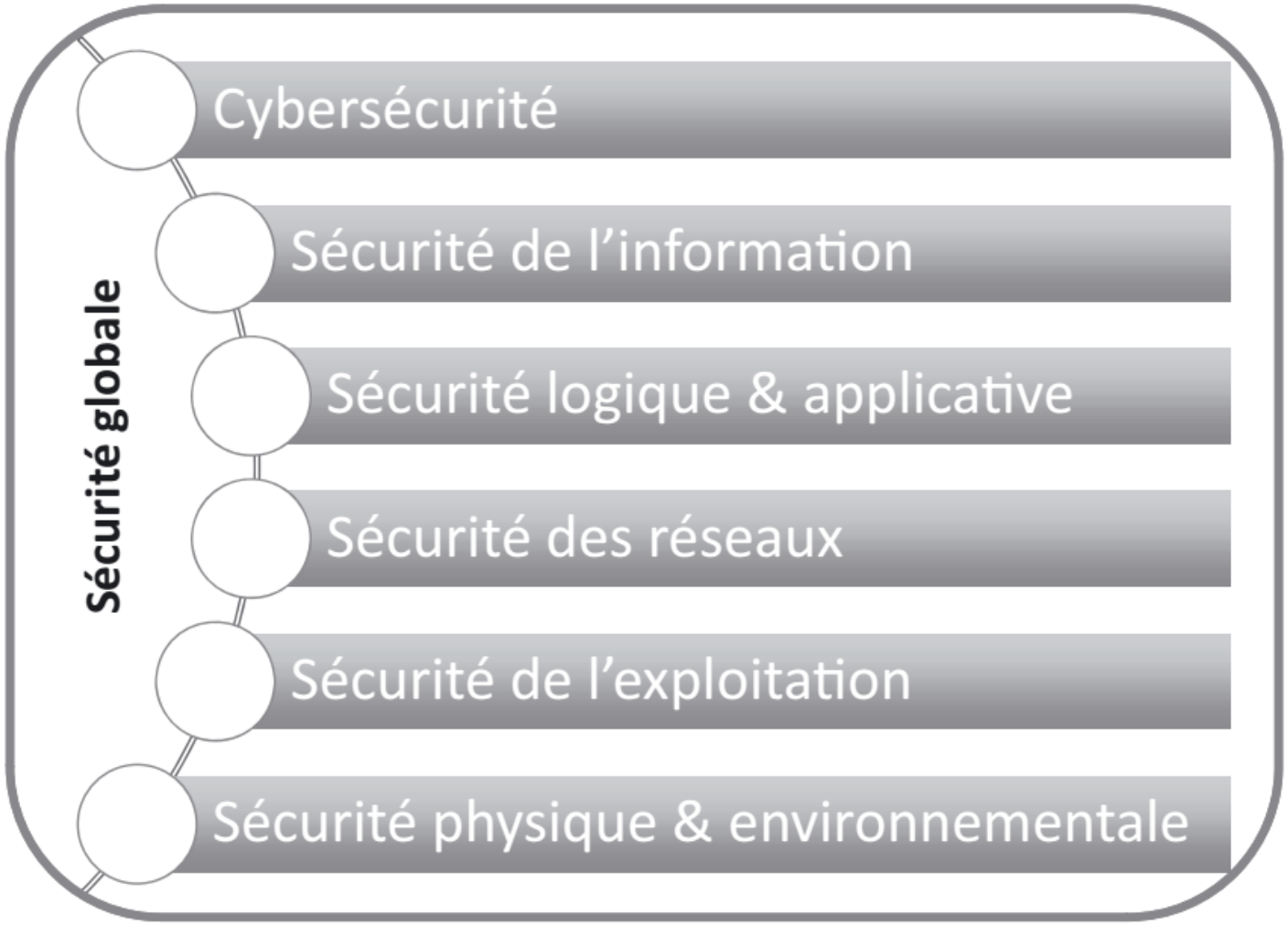


- Confidentialité et intégrité des données
  - seuls les ayants droit identifiés et authentifiés peuvent accéder aux ressources (contrôle d'accès) et les modifier
- Non-répudiation et imputabilité
  - Seules les entités identifiées et authentifiées ont pu réaliser une certaine action (preuve de l'origine d'un message ou d'une transaction, etc.)
  - Traçabilité

Non-répudiation

- Le fait de ne pouvoir nier ou rejeter qu'un évènement (action, transaction) a eu lieu
- Imputabilité
  - L'attribution d'une action (un évènement) à une entité déterminée (ressource, personne)
  - Enregistrement fiable d'informations sur les entités et les évènements
- Traçabilité
  - Suivre la trace numérique laissée par la réalisation d'un évènement
- L'auditabilité
  - La capacité d'un système à garantir la présence d'informations nécessaires à une analyse ultérieure d'un évènement (courant ou exceptionnel)

Domaines d'application de la sécurité informatique



Cybersécurité

- Le préfixe « cyber » est devenu relatif à l'environnement informatique et aux activités rendus possibles par les technologies du numérique
- **Cyberespace**
  - L'ensemble des infrastructures numériques, des données et des services mis en réseaux
  - Extension de notre espace naturel qui reflète notre société avec ses réalités politique, économique, sociale et culturelle
- **Cybersécurité**
  - Concerne la sécurité informatique et des réseaux des environnements connectés à Internet et accessible *via* le cyberespace
  - Peut être mise en défaut, entre autres, par des **cyberattaques** informatiques
- Usage extensif d'Internet ➔
  - Nouvelles menaces générant des risques additionnels
  - Impact potentiel sur les individus, les organisations ou les états

Sécurité de l'information

- Bien **protéger l'information** c'est
  - Comprendre son rôle et son importance stratégique
  - L'impact des décisions qui la concernent
  - Assurer son **exactitude** et sa **pérennité**
- Classification des données pour qualifier leur degré de sensibilité (confidentielles, privées, sensibles, publiques) et les protéger en conséquence
- Respect de l'intimité numérique (*privacy*) de l'utilisateur et de ses données personnelles

Sécurité logique et applicative

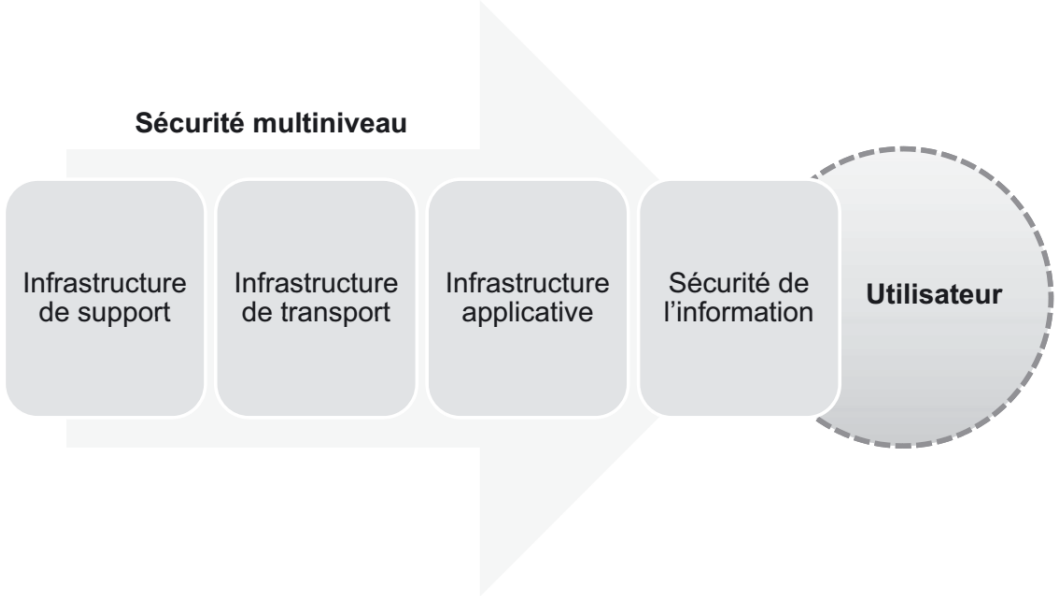
- La **sécurité logique** fait référence à la réalisation de mécanismes de sécurité par logiciel contribuant au bon fonctionnement des programmes, des services offerts et à la protection des données
  - La qualité des développements logiciels et des tests de sécurité
  - Une mise en œuvre adéquate de la cryptographie (intégrité et confidentialité)
  - Des procédures de contrôle d'accès logique et d'authentification
  - Des procédures de détection de logiciels malveillants, de détection d'intrusion et d'incidents
  - Dimensionnement suffisant de ressources, redondance, sauvegarde
  - Etc.

Sécurité logique et applicative (suite)

- La **sécurité applicative** comprend le développement pertinent de solutions logiciels ainsi que leur intégration et exécution harmonieuse dans des environnements opérationnels
  - Une méthodologie de développement
  - La robustesse des applications
  - Des contrôles programmés
  - Des jeux de tests
  - Des procédures de recettes
  - L'intégration des mécanismes de sécurité
  - La sécurité des progiciels (choix des fournisseurs, etc.)
  - Un plan de migration des applications critiques
  - La validation et l'audit des programmes
  - La qualité et la pertinence des données
  - Etc.

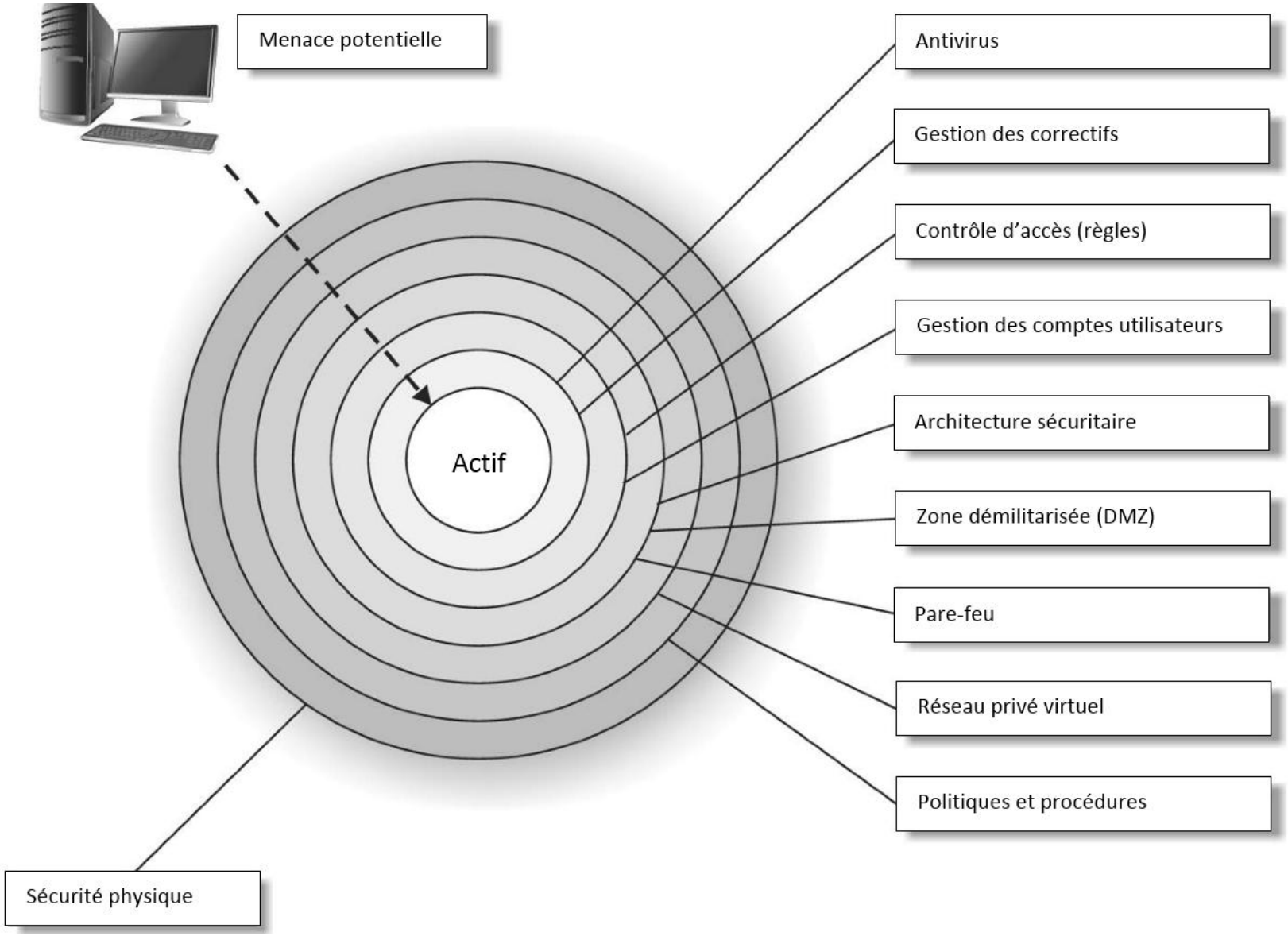
Sécurité des réseaux

- Sécurité des infrastructures de télécommunication
- Consiste à offrir à l'utilisateur final et aux applications communicantes une connectivité fiable « de bout en bout »
  - Réalisation d'une **infrastructure réseau** sécurisée au niveau des accès au réseau et du transport
  - Usage de plates-formes matérielles et logicielles sécurisées et une gestion de réseau de qualité
- N'est qu'un maillon dans la chaîne sécuritaire ➔ **La sécurité est toujours celle du maillon le plus faible!**
  - Besoin de sécuriser l'**infrastructure informatique**



Sécurité des réseaux (suite)

- Défense en profondeur



Sécurité de l'exploitation

- Permet un bon fonctionnement opérationnel des systèmes informatiques
  - Gestion du parc informatique
  - Gestion des configurations et des mises à jour
  - Gestion des incidents et suivi jusqu'à leur résolution
  - Plan de sauvegarde
  - Plan de secours
  - Plan de continuité
  - Plan de tests
  - Analyse des fichiers de journalisation et de comptabilité
  - Gestion des contrats de maintenance
  - Séparation des environnements de développent et de production des applications
  - Etc.

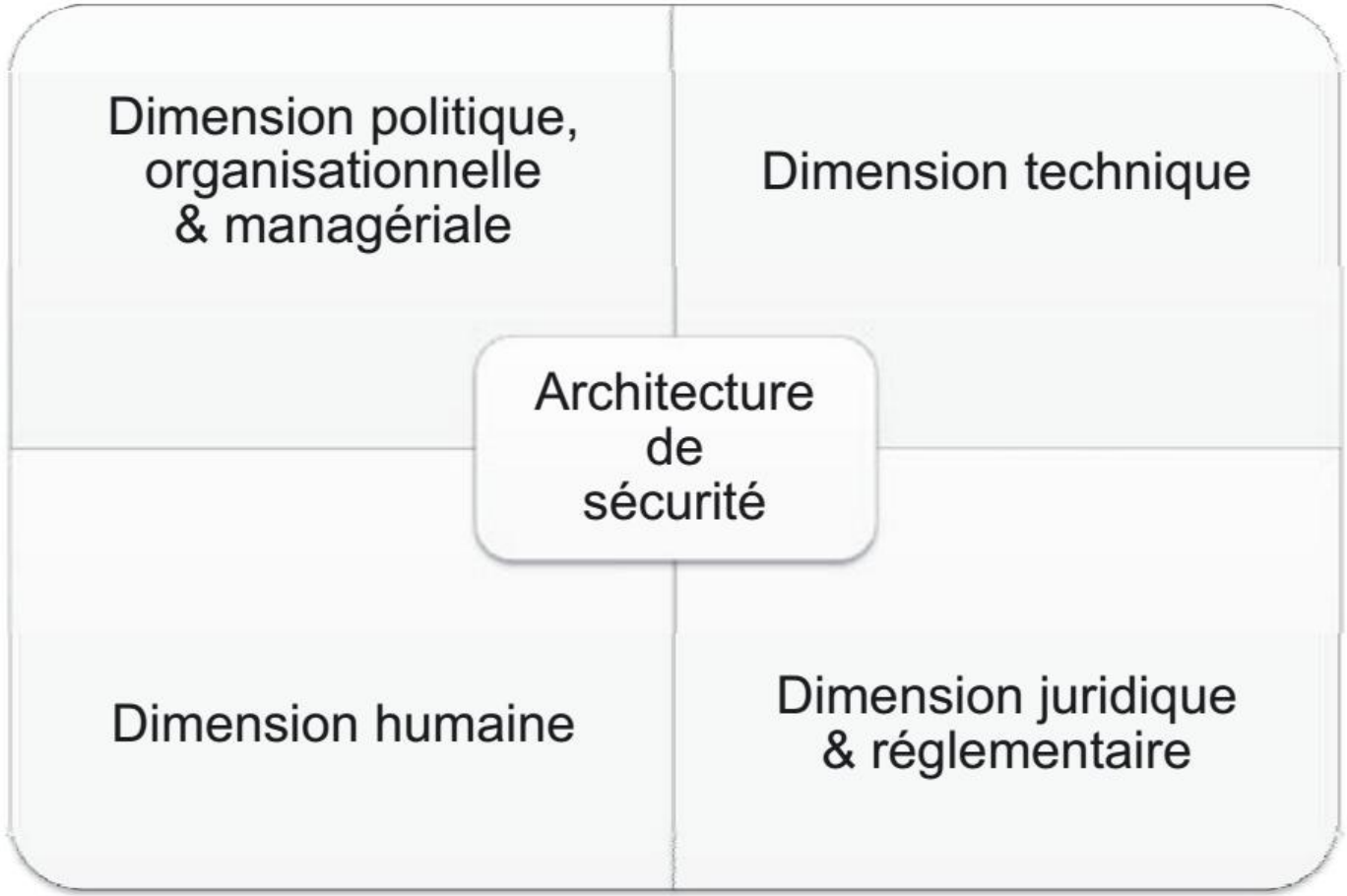
Sécurité physique et environnementale

- Concerne tous les aspects liés à la maîtrise des systèmes et de l'environnement dans lequel ils se situent
  - La protection des sources énergétiques et de la climatisation
  - La protection de l'environnement (risques d'incendie, d'inondation, etc.)
  - Gestion et contrôle des accès physiques aux locaux
  - La redondance physique des infrastructures et sources énergétiques
  - Marquage du matériel pour dissuader le vol
  - Le plan de maintenance préventive (tests) et corrective (pièces de rechange)
  - Etc.

Diriger la sécurité

- Définition d'une **politique de sécurité**
- La motivation et la **formation** du personnel
- La mise en place de mesures **proactives** et **réactives**
- L'**optimisation** de l'usage des technologies de l'information et de communication et des solutions de sécurité

Les besoins de sécurité doivent être clairement identifiés et constamment réévalués au regard des risques encourus et de leur évolution.

Architecture de sécurité

- L'ensemble des dimensions organisationnelle, juridique, humaine et technologique de la sécurité informatique